✦ LUMI

PROJETO FULL-STACK • IA & PRIVACIDADE

Lumi: Iluminando Ideias com Inteligência Artificial e Privacidade

PWA responsivo integrado ao Google Gemini via BYOK, arquitetura Serverless BFF e criptografia ponta a ponta Zero-Knowledge.

React 19 | TypeScript | Vite | Tailwind CSS v4 | TursoDB (Hrana v2) | Google Gemini REST | Argon2id (WASM) | AES-256-GCM | Serverless BFF

Autor: **Davy Andrade**

Atividade AP5 - 5PDM

O Problema: Bloqueio Criativo e Riscos na Nuvem

Obstáculos no processo de inovação de desenvolvedores, empreendedores e criadores de conteúdo.

⚡ Bloqueio Criativo e Dispersão

Dificuldade frequente em articular pensamentos difusos em ideias práticas, viáveis e estruturadas (com proposta de valor, público-alvo e nicho bem definidos).

🔒 Exposição de Propriedade Intelectual

Ferramentas convencionais de ideação na nuvem armazenam dados em texto claro nos servidores. Ideias confidenciais e projetos de negócios ficam expostos a vazamentos.

💸 Custos e Dependência Centralizada

Plataformas que intermediam IA cobram assinaturas elevadas ou sofrem com limites rígidos de requisições, tornando a infraestrutura cara e com alto risco de lock-in.

A Solução: Lumi — Inteligente, Privado e Portátil

Uma plataforma de ideação estruturada com custo zero de infraestrutura e criptografia soberana.

💡 Ideação Estruturada por IA

Geração instantânea de títulos cativantes, descrições detalhadas e enquadramento em categorias mercadológicas pré-definidas através do Google Gemini.

🔑 Paradigma BYOK (Bring Your Own Key)

O usuário conecta sua própria chave gratuita do Google AI Studio. Sem repasse de custos, sem intermediários lendo as consultas e com cota individual direta.

🛡️ Soberania Zero-Knowledge

Criptografia client-side ponta a ponta: senhas e ideias são cifradas antes de saírem do navegador. O servidor armazena dados sem ter a capacidade matemática de lê-los.

O Aplicativo: PWA Moderno e Focado na Experiência

Construído com React 19, Tailwind CSS v4 e princípios de acessibilidade e responsividade.

✨ Tela de Ideação

Saudação personalizada pelo primeiro nome, tags de categorias de um clique (App, Negócio, Conteúdo, etc.) e geração em tempo real com indicador visual de progresso.

📂 Histórico & Filtros

Listagem completa das ideias do usuário autenticado com filtragem dinâmica por categoria, alternador de favoritas e busca textual em memória após decifrar.

⚙️ Configurações & BYOK

Gestão segura da chave de API do Gemini, alternância entre 9 modelos suportados e teste de conectividade ao vivo com validação imediata.

📱 PWA & Dark Mode

Instalável nativamente no desktop e smartphone (Service Worker cache-first), navegação rápida por abas inferiores e alternância de tema Claro/Escuro.

Arquitetura de Software: Padrão Serverless BFF

Desacoplamento estrito em 3 camadas para garantir isolamento de banco e segurança operacional.

🖥️ 1. Camada de Apresentação (PWA)

- ✦ React 19 + TypeScript (tipagem 100% estrita).
- ✦ Derivação de chaves e cifragem no navegador (Argon2id WASM + AES-256-GCM).
- ✦ Zero comunicação direta com o banco: todo acesso passa pelo cliente HTTP `api-client.ts`.

⚡ 2. Backend-For-Frontend (BFF)

- ✦ Vercel Serverless Functions padronizadas com Web Fetch API (`Request` / `Response`).
- ✦ Rotas modulares sob `/api/*`: auth, ideias e perfil do usuário.
- ✦ Autenticação stateless via Bearer Token JWT (HS256) e injeção do `usuario_id`.

☁️ 3. Persistência & IA Externa

- ✦ TursoDB na borda com Hrana v2 (apenas o BFF detém as credenciais do banco).
- ✦ Google Gemini REST direto do cliente usando a chave BYOK do usuário no header `x-goog-api-key`.

Persistência na Borda e Web Services RESTful

TursoDB via HTTP Pipeline v2 e endpoints serverless de alta performance e isolamento multitenant.

🗄️ TursoDB (Edge SQLite / Hrana v2)

✦ **Protocolo Hrana v2 sobre HTTPS:** Comunicação rápida via HTTP Pipeline v2, dispensando binários nativos C/C++ ou `@libsql/client` pesado.

✦ **Isolamento Multi-inquilino:** Todas as consultas de ideias são estritamente filtradas por `usuario_id` vinculado ao token JWT validado.

✦ **Criptografia em Repouso:** Campos confidenciais são armazenados exclusivamente como ciphertext (AES-GCM) e credenciais como PHC Argon2id.

✦ **Schema Relacional Enxuto:** Tabelas `usuarios` e `ideias` com chave estrangeira e integridade referencial.

🌐 Web Services Serverless (`/api/*`)

✦ **Auth Endpoints:** `/api/auth/registrar`, `/api/auth/login` e `/api/auth/sessao` para ciclo de vida de autenticação.

✦ **CRUD de Ideias:** `GET /api/ideias` (listar), `POST /api/ideias` (criar com E2E), `PATCH` (favoritar) e `DELETE`.

✦ **Configurações do Usuário:** `/api/usuario/config` e `/api/usuario/perfil` para troca de modelo e sincronização de chaves cifradas.

✦ **Zero Vazamento de Segredos:** Tokens de banco e Pepper ficam confinados nas variáveis do servidor Vercel.

Engenharia de IA: Prompts, Schemas e Integração REST

Como a inteligência do Lumi foi desenvolvida, calibrada e integrada sem intermediários pesados.

🎯 Engenharia de Prompt e Taxonomia

✦ **Persona Especialista:** Prompt do sistema atua como estrategista de inovação, forçando ideias acionáveis e diferenciadas.

✦ **Direcionamento por Categorias:** Classificação estrita em 5 pilares do mercado: App, `Negócio`, `Conteúdo`, `Open Source` e Hobby.

✦ **Restrições Negativas:** Diretrizes para evitar jargões genéricos, introduções vazias e alucinações conceituais.

📐 Structured Outputs (JSON Schema Nativo)

✦ **Garantia de Esquema:** Uso de `responseMimeType: "application/json"` com `responseSchema` formal do Gemini v1beta.

✦ **Campos Fortemente Tipados:** Retorno restrito a `titulo` (conciso), `descricao` (com dor e solução) e `categoria` (enum restrito).

✦ **Zero Falhas de Parse:** Dispensa regex ou heurísticas no frontend; a IA gera JSON válido diretamente no nível de token.

```
Endpoint REST: POST https://generativelanguage.googleapis.com/v1beta/models/{modelo}:generateContent Header: x-goog-api-key: {BYOK_USER_KEY} | Modelos: gemini-2.5-flash, gemini-2.5-pro, gemma-4-26b-it
```

Segurança Criptográfica Zero-Knowledge

Matematicamente impossível para o servidor inspecionar os segredos dos usuários.

🔐 Argon2id (WebAssembly)

Algoritmo de ponta (vencedor do PHC). Executado no cliente consumindo 19 MiB de memória com 3 iterações. Gera hash PHC canônico com salt embutido (OWASP).

🛡️ HMAC-SHA256 Pepper

Segredo server-side injetado antes do hash. Impede ataques de dicionário e tabelas rainbow mesmo em caso de dump não autorizado do banco.

🔑 AES-256-GCM End-to-End

Chave de cofre de 256 bits derivada localmente. Chave Gemini, descrição da ideia e prompt são cifrados com IV aleatório de 96 bits por registro.

```
Fluxo E2E: Senha → Pepper (HMAC) → Argon2id → vaultKeyHex → AES-256-GCM (Ciphertext) → TursoDB
```

Engenharia de Qualidade: Testes e Confiabilidade

Desenvolvimento guiado por testes rigorosos, tipos estritos e alta eficiência de build.

98
Testes Automatizados Passando (Vitest)

0
Erros de Tipagem TypeScript (tsc --noEmit)

~1.3s
Tempo de Build de Produção (Vite)

🧪 Cobertura Unitária e Integração

Testes abrangem criptografia (Argon2id, HMAC, AES-GCM), cliente Gemini REST, rotas serverless do BFF e queries SQL com TursoDB.

🚀 Vercel Deploy & PWA Cache

Configuração `vercel.json` otimizada com roteamento para SPA e serverless functions, além de cache agressivo para o Service Worker.

Conclusão do Projeto & Demonstração Prática

Entrega de um produto real, robusto, escalável e alinhado aos padrões da indústria.

🎯 Principais Diferenciais

- ✦ **Problema & Solução:** Ideação criativa guiada sem bloqueios e sem dispersão.
- ✦ **Aplicativo:** PWA veloz, responsivo e instalável com Dark Mode e filtros.
- ✦ **Arquitetura & BD:** Serverless BFF desacoplado e TursoDB na borda com isolamento.
- ✦ **Inteligência Artificial:** Gemini REST puro com Structured Outputs (JSON Schema).
- ✦ **Privacidade:** Segurança Zero-Knowledge e criptografia AES-256-GCM ponta a ponta.

🎬 Roteiro de Demonstração

- ✦ **1. Cadastro de Usuário:** Senha forte e derivação Argon2id no browser.
- ✦ **2. Configuração BYOK:** Registro seguro de chave Gemini cifrada no cofre.
- ✦ **3. Geração de Ideia:** Consulta ao modelo com Structured Outputs em tempo real.
- ✦ **4. Histórico E2E:** Filtragem reativa e inspeção do banco em ciphertext.

• PWA EM PRODUÇÃO

`https://lumi-gen.vercel.app/`

Aponte a câmera do celular para testar o app em tempo real.